Evidence-Grounded Local Language Models and Behavioral Telemetry for Defensive Network Review

João Vitor Ielen and Vinicius Mota Favaro
Centro Universitário UniOpet, Curitiba, Paraná, Brazil
Academic advisor: Michel Cesar dos Santos

Abstract

Security review requires a distinction between observed behavior, model interpretation, and an authorized response. This study evaluates an architecture that preserves those boundaries while using local language models (LLMs) to organize behavioral findings. The artifact combines authorized Nmap inventory with normalized telemetry, applies four transparent rules, and checks model outputs against exact evidence identifiers and a fixed control policy. Evaluation covers constructed fixtures, family-separated CTU-13 flows, a synthetic transfer source, and a 180-attempt matrix spanning three models and three prompts, with supplementary adversarial and ablation tests. Detector performance varied by scenario: the inspected NSIS.ay holdout yielded F1 0.317 and Matthews correlation coefficient (MCC) -0.282; the prospectively frozen DonBot holdout yielded F1 0.600 and MCC 0.452. These are separate evaluations, not a paired estimate of improvement. In the primary LLM matrix, 145 attempts returned responses and 73 passed the deterministic validator. No primary multi-finding attempt passed; a nine-call conflicting-context supplement also produced no accepted response. The results demonstrate machine-checkable traceability and rejection of contract violations, but do not establish correct prioritization or benefit to analysts. The contribution is an auditable integration and a documented account of its failure modes. The evaluated system provides no evidential basis for autonomous attribution or containment.

Index Terms

network telemetry, local language model, behavioral detection, CTU-13, defensive automation

1. Introduction

Security tools expose observations that require interpretation. Nmap reports reachable hosts, open ports, and uncertain service fingerprints [1], [2]; endpoint telemetry can link connections, DNS queries, and file creation to processes [3]. These records can motivate investigation, but an open port does not establish exploitability, and a suspicious connection pattern does not establish compromise. A review system must preserve that distinction as it moves from collection to explanation and response.

Large language models (LLMs) offer a possible interface for organizing such evidence. Their fluency, however, can make unsupported interpretations appear conclusive. Local execution limits disclosure to external inference services; it does not establish the accuracy of a recommendation. The NIST AI Risk Management Framework accordingly emphasizes governance, measurement, and continued risk management [4]. The engineering question addressed here is how to make model interpretations inspectable and rejectable before they acquire operational authority.

The artifact extends an undergraduate project approved in 2025 that parsed authorized Nmap XML, generated reports, and optionally requested local Ollama narratives. The present study evaluates a narrower role for the model: it may prioritize supplied findings and propose controls from a fixed catalog, while deterministic code retains ownership of observations and rule evaluation. A separate validator checks the output, and the model has neither execution credentials nor authority to initiate a response. The approved monograph remains a historical record; the research extension is evaluated independently.

Three research questions define the evaluation. **RQ1:** How do the transparent behavior rules perform on constructed fixtures and independently labeled external flows? **RQ2:** How consistently do constrained local LLM outputs preserve exact evidence references and satisfy the implemented policy, including under adversarial input? **RQ3:** What response boundaries are supported by the observed detector errors and output failures? The reconstructed 2025 free-text protocol provides a historical traceability comparison for RQ2; it is not a controlled test of comparative semantic quality.

The contribution has two parts. First, the artifact integrates normalized telemetry, stable evidence identifiers, explicit behavior rules, constrained local generation, and independent output validation into an auditable review pipeline. Second, the evaluation documents where that integration fails, distinguishing detector errors, output-contract violations, and runtime unavailability. It includes a prospectively frozen family-separated holdout, multi-model and prompt comparisons, adversarial inputs, and offline response-policy counterfactuals. The study does not introduce a new language model or claim state-of-the-art intrusion detection. Analyst benefit, ranking correctness, and production effectiveness remain unmeasured.

2. Foundations and Evidence Boundary

A. From scan observations to behavioral review

An open port is an endpoint, not a confirmed vulnerability. Product identity, affected version, configuration, reachability, authentication, and compensating controls determine its security significance. Similarly, periodic traffic, rapid contact with distinct endpoints, and asymmetric byte counts are dual-use patterns. Routine software updates, browsers, backups, monitoring, and authorized administration can exhibit them.

MITRE ATT&CK documents behaviors such as application-layer command traffic, network service discovery, exfiltration over an existing channel, and ingress tool transfer [5]. These techniques provide analytical context for the rules. A match is labeled `behavior-review`; it does not assert that an ATT&CK technique, malware family, compromise, or exploitable vulnerability occurred.

The external corpus is CTU-13, a set of thirteen scenarios containing labeled botnet, normal, and background network traffic [6], [7]. The publisher warns that inbound `To-Botnet` traffic is not necessarily malicious. This study therefore scores only source-origin `From-Botnet` and `From-Normal` records and excludes background and all `To-*` labels.

B. Grounded local inference

Ollama supports local inference and JSON-schema structured outputs [8], [9]. A schema can constrain representation, but it cannot prove semantic correctness. The implemented validator consequently checks that every cited finding and event identifier existed in the supplied evidence, rejects unsupported CVEs and absolute compromise claims, requires complete finding coverage, and permits only controls pre-mapped to each transparent rule.

The system distinguishes a scan observation, a normalized event, a rule match, a model interpretation, and an independent analyst conclusion. A rule match is a candidate for review. Its metadata explicitly records that malware and vulnerability are unconfirmed and that automatic response is not authorized. Throughout this article, *accepted* means that an output passed the implemented deterministic contract; it does not mean that its interpretation was independently judged correct.

3. Related Work and Positioning

Network anomaly detection has long faced a gap between closed-world evaluation and operational deployment. Sommer and Paxson identify high error costs, a semantic gap between alerts and operational meaning, variable benign traffic, evaluation difficulties, and adversarial conditions [10]. Buczak and Guven catalog the broad range of data-mining and machine-learning methods applied to intrusion detection [11]; that methodological breadth does not remove the deployment constraints identified by Sommer and Paxson. CTU-13 supplies labeled botnet, normal, and background flows and has supported many botnet classifiers [6]; however, a family label is not proof that every source-window contains a rule-observable malicious action. The family-separated holdout is therefore used as a stress test of fixed review heuristics, not as evidence of state-of-the-art botnet classification.

Explainable intrusion-detection research seeks to expose why a model alerted and to make that explanation usable by analysts. Neupane et al. identify stakeholder-specific explanations and human-in-the-loop design as open requirements for X-IDS [12]. HuntGPT combines an anomaly detector, post-hoc explanations, and a conversational model for analyst-facing interpretation [13], while graph-based incident triage correlates alerts with asset and attack-stage context before assigning severity [14]. These systems motivate analyst assistance, but explanation quality and detection accuracy remain separate constructs. In this artifact, the rules are directly inspectable, every match retains its event identifiers, and the model is an untrusted prioritization layer rather than the owner of detection truth.

One preprint review and two peer-reviewed reviews place LLMs across SOC detection, analysis, threat-intelligence, and response workflows, while identifying limitations in datasets, evaluation, privacy, reliability, and governance [15], [16], [17]. More focused peer-reviewed work uses retrieval and constrained planning to reduce hallucination in incident response [18]. A recent preprint also evaluates reasoning-enabled alert triage on human-labeled endpoint detections [19]. These studies use LLMs as decision aids, but a plausible recommendation may still be unauthorized or wrong. The model in this study therefore receives no action credentials and cannot bypass independent confirmation or human approval.

Structured generation addresses representation but not semantic truth. JSONSchemaBench finds meaningful differences in constraint coverage, efficiency, and output quality across decoding frameworks even when JSON Schema is the common interface [20]. Human-AI interaction guidance similarly emphasizes communicating uncertainty, supporting correction, and preserving user control when an AI system is wrong [21]. Here, a closed schema prevents unbounded response shapes, while a separate deterministic validator checks identifier provenance, complete finding coverage, forbidden attribution, and rule-applicable controls. Schema validity, evidence grounding, and semantic-policy acceptance are reported independently.

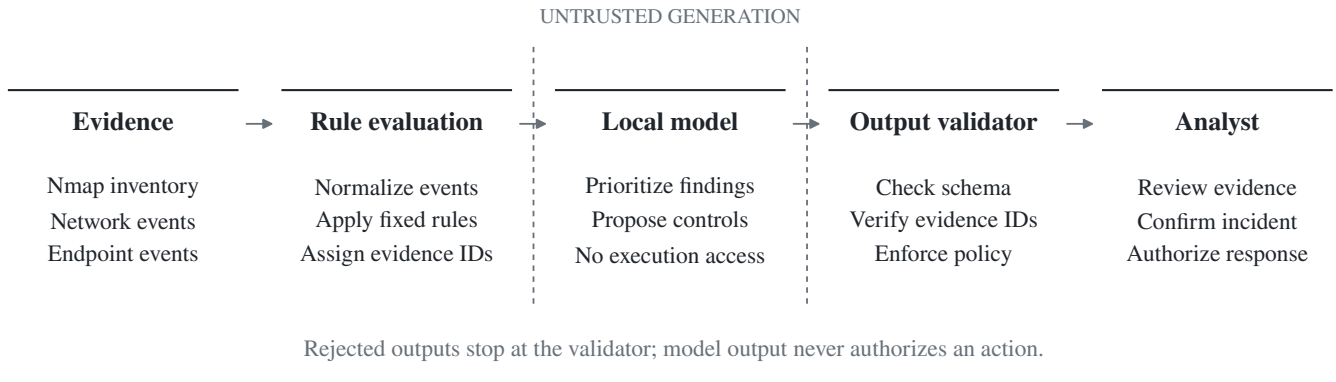
Telemetry is also an adversarial input surface. Indirect-prompt-injection research examines the boundary between application instructions and externally controlled data [22]. A recent SOC-specific preprint places instructions inside log fields and reports residual decision manipulation under constrained output and prompt hardening [23]. The present artifact treats telemetry strings as untrusted and evaluates output changes without granting the model execution tools. Its positioning is the integration and evaluation of these safeguards in a small, reproducible review pipeline, rather than a claim that any individual safeguard is novel or sufficient.

4. Artifact Design

A. *Trust-boundary architecture*

Figure 1 separates deterministic evidence processing, untrusted generation, output validation, and analyst review. The model receives an evidence pack and may return a candidate interpretation. A rejected output stops at the validator. A passing output remains advisory; independent confirmation and authorization belong to the analyst and any separately controlled response system.

Figure 1. Review architecture. Dashed boundaries separate untrusted model generation from deterministic processing and validation. Passing validation does not authorize a response.



Source: Research design (2026).

B. *Transparent behavior rules*

The detector implements four predeclared rules. `BEH-001` requires at least six near-periodic connections to one endpoint with interval coefficient of variation at most 0.15. `BEH-002` requires at least eight distinct endpoints within 60 seconds. `BEH-003` requires at least 1 MB sent and a sent-to-received ratio of at least 10:1. `BEH-004` correlates at least 32 KiB received with executable-like file metadata within 120 seconds. Thresholds were frozen before external-label inspection.

Each finding records rule ID, stable finding ID, host, process context when available, exact evidence IDs, threshold observations, and interpretation limits. Nmap inventory may add authorized asset context but does not change the label. The detector produces review candidates only and invokes no firewall, quarantine, process termination, or file deletion action.

The V1.1 endpoint schema adds bounded optional fields for executable path, signer, parent process, pseudonymous user context, command line, and SHA-256. It excludes credentials, message bodies, keystrokes, packet payloads, and file contents; text is capped at 1,024 characters and hashes are syntactically validated. These fields provide review context and lineage but do not themselves confirm maliciousness.

C. LLM protocol and controls

The grounded protocol uses local Ollama on loopback with a 4,096-token context, 700-token output ceiling, temperature zero, seed 42, and closed schema. V1.1 evaluates `llama3.2:3b`, `gemma3:4b`, and `qwen3:8b` under Ollama 0.32.13; exact manifest digests and quantization records are frozen with the matrix. The historical control runs used Ollama versions 0.32.5 and 0.32.6 and a preserved Llama blob hash. Scan- or event-controlled strings are delimited as untrusted data. The model selects explanations and proposed controls from the evidence pack and a fixed catalog; it holds no operating-system, Zabbix, or firewall credential.

The control reconstructs the historical technical free-text path with temperature 0.7 and `top_p`=0.9, no system prompt, and no output schema. Both protocols receive the same observations, but the control is not a byte-exact replay: fixed context, output, and timeout limits were added for reproducibility.

5. Method

A. Study design

The study follows an applied Design Science Research structure: artifact construction, demonstration, evaluation, and communication [24]. The 2025 monograph is treated as a historical record, while the experiments reported here use new code and evidence. The confirmatory boundary was defined before the final repetitions: exploratory outputs that influenced a metric or rubric cannot be reused as confirmatory evidence.

The evaluation comprises five components with distinct evidentiary roles (Figure 2). Phase A checks implementation behavior on constructed cases. Phase B1 evaluates the historical Virut/NSIS.ay pair and diagnoses its errors retrospectively. Phase B2 selects thresholds on RBot and evaluates a prospectively frozen DonBot holdout. Phase B3 tests implementation transfer on synthetic flows derived from CTU-13 patterns. Phase C measures local-model output compliance, availability, component sensitivity, and responses to inert prompt injection. These components do not constitute independent replications of a single performance estimate. No blinded human assessment or live-response trial was conducted.

B. Execution environments and comparison boundary

The preserved V1.0 runs and the V1.1 development environment differ materially, as summarized in Table 1. V1.0 model inference ran on the CPU of an Intel Core i5-1335U system with approximately 16 GiB RAM, first under Windows and then under Debian. The V1.1 development system has an AMD Ryzen 5 5600, approximately 32 GiB RAM, and an NVIDIA RTX 3060 with 12 GiB VRAM. At inventory time, no V1.1 experiment had been executed on the newer machine.

These differences affect model placement, memory pressure, drivers, runtime versions, and latency. Timing across V1.0 and V1.1 is therefore reported only as provenance and cannot identify a protocol-speed or model-speed effect. Any V1.1 comparison intended to isolate a model, prompt, schema, or validator change must execute all compared conditions on the same frozen environment.

C. Phase A: inert functional fixtures

Six committed JSON Lines scenarios contain no sockets, payloads, persistence mechanisms, or operating-system changes. They represent irregular benign browsing, a legitimate periodic updater as a hard negative, and four emulated patterns corresponding to the four rules. The unit is a scenario-rule pair, yielding 24 binary units. Expected labels were declared in the scenario manifest before execution.

Figure 2. Evaluation map. Rows describe distinct evidence roles rather than a sequential experiment; their metrics are not pooled.

Evaluation	**Evidence**	**What it evaluates**
A Functional	Constructed network and endpoint cases	Implementation conformance
B1 Historical	Virut development; NSIS.ay holdout	Rule errors and window sensitivity
B2 Prospective	RBot development; frozen DonBot holdout	Performance on one unseen family
B3 Transfer	CTU-13-derived synthetic flows	Parser and representation transfer
C Local LLM	Three models; prompts and adversarial pairs	Traceability, policy and availability

Not evaluated: benefit to analysts, production effectiveness or live containment.

Source: Research design (2026).

Table 1
Execution-environment provenance for the preserved V1.0 runs and V1.1 development.

Research state	V1.0 initial run	V1.0 confirmatory repetitions	V1.1 development environment
Operating system	Windows 11 build 26200	Debian GNU/Linux, kernel 6.12.101	Windows 10 Pro 22H2 build 19045
CPU	Intel Core i5-1335U	Intel Core i5-1335U	AMD Ryzen 5 5600
Topology	12 logical processors	10 cores / 12 logical processors	6 cores / 12 logical processors
RAM (GiB)	15.7	15.4	31.9
Inference device	CPU; Intel Iris Xe present	CPU	NVIDIA RTX 3060, 12 GiB VRAM

Note: The V1.1 row is an environment inventory, not evidence that a V1.1 experiment had already run. Cross-machine latency is descriptive only because hardware, operating system, driver, runtime version, and CPU/GPU placement differ.

Source: Research data (2026).

Table 2
Frozen Phase-A synthetic behavior-rule result.

TP	FP	FN	TN	Precision	Recall	F1	Specificity
4	1	0	19	0.800	1.000	0.889	0.950

Source: Research data (2026).

The frozen Phase-A result is summarized in Table 2. It must not be combined with external-validation metrics because it measures implementation conformance to constructed patterns, not real-world detection accuracy.

A separate five-case endpoint matrix evaluates `BEH-004`: one same-process download/file sequence and four negatives varying bytes, process identity, timing, and file suffix. Every event contains synthetic process lineage and pseudonymous user context. The matrix is executed both with and without Nmap inventory to distinguish contextual enrichment from rule behavior.

D. Phase B1: historical external flow validation

Data selection was frozen before complete-label inspection. CTU-13 Scenario 5 (Virut) is the development source, while Scenario 12 (NSIS.ay) is the family-separated holdout. Only the publisher-recommended bidirectional `.binetflow` text files were acquired. Their provenance is fixed by these SHA-256 values:

```
Scenario 5: ef5c9ed6895d4ca5aec723449dae3005
        4ccd1f6b091713a52ffcb681ff78a02c
Scenario 12: 1098f0addacedc321c7baefad63ef0d9
        a0f26630d0155087d37e8da770dd9f2e
```

Acquisition code rejects executables, archives, packet captures, and binary Argus files.

The scored unit is an anonymized source host in a non-overlapping five-minute window. Addresses are replaced by stable scenario-local hashes before detection, and labels are never supplied to the detector. Positive windows contain `From-Botnet` source flows; negative windows contain `From-Normal` source flows. Mixed, background, inbound, and unsupported-protocol records are counted and excluded.

The adapter creates normalized connection events from flow direction and byte counts. CTU-13 flow records have no endpoint process identity or file lineage, so only `BEH-001` through `BEH-003` are evaluated. `BEH-004` is explicitly out of scope. Scenario 5 was available for development interpretation, but thresholds were not retuned. Scenario 12 remained the held-out report set.

After the V1.0 result had been finalized and inspected, both sources were reopened for a predeclared V1.1 retrospective diagnostic. Without changing rule thresholds, the adapter formed non-overlapping source-host units of 60, 300, and 600 seconds. It then decomposed each rule into observable components: connection count, eligible mean interval and interval variation for `BEH-001`; maximum distinct destinations in any 60-second interval for `BEH-002`; and absolute sent bytes and sent-to-received ratio for `BEH-003`. Deterministic class/time/host ordering selected one TP, FP, and FN example. This reuse can explain failure modes and window sensitivity, but it cannot support model selection on the holdout or make that holdout untouched again.

E. Phase B2: prospective family-separated holdout

Before downloading or parsing the new files, Scenario 11 (RBot) was assigned to development and Scenario 6 (DonBot) to the sole confirmatory holdout using official capture metadata and HTTP headers. The primary unit and label policy remained the five-minute source-host definition used in Phase B1. A frozen 243-member grid varied `BEH-001` minimum count and interval variation, `BEH-002` destination count, and `BEH-003` byte and ratio components. Selection maximized development MCC, followed by balanced accuracy, F1, specificity, distance from V1.0, alert count, and deterministic parameter order.

All candidates were evaluated only on RBot. The complete grid, selected configuration, anonymized units, acquisition hashes, and scientific source hashes were preserved before DonBot was parsed. The holdout executor rejected any source-state change and wrote to a previously absent immutable directory. It then evaluated DonBot exactly once. The original preselection record contained a timestamp transcription error; both its hash and a corrected record with the observed pre-download creation time are retained with an explicit erratum. Dataset roles, grid, and gates did not change.

F. Phase B3: second-dataset implementation transfer

The Botnet Group Activity Dataset contains 13 synthetic eight-hour scenarios in the same 15-column `.binetflow` representation [25], [26]. Its generator adopts activity patterns from CTU-13; it is therefore not independent evidence of real-world generalization. Before downloading the archive or inspecting scenario labels, Scenario 1 was selected for an implementation-transfer replay. Archive and extracted-file byte counts and SHA-256 hashes were verified, and the selected V1.1 thresholds were not changed.

The five-minute source-host unit and label policy remained unchanged. A dataset-specific parser profile expanded only the file/row bounds, accepted the published hyphenated timestamps, used a separate anonymization namespace, and normalized the unspecified source timezone to UTC solely for within-source bucketing. To bound memory and output for 2.1 million rows, the run preserved aggregate confusion counts, truth-separated rule combinations, and the first deterministic example per combination rather than every unit. These results are reported separately from every CTU-13 role.

G. Phase C: repeated protocol comparison

The primary V1.1 matrix uses three quantized local models from different families and sizes: `llama3.2:3b`, `gemma3:4b`, and `qwen3:8b`. Exact local manifest digests, registry records and byte sizes were frozen before inference. Each model receives three semantically equivalent prompt variants: contract, evidence-first, and checklist. All variants use the same evidence pack, output schema, validator, scenario order, temperature zero, `top_p`=0.9, seed 42, 4,096-token context, and 700-token output ceiling.

Five clustered repetitions cover a no-finding case, a benign periodic-updater hard negative, an incomplete single observation, an endpoint-lineage case, and a 17-event case producing all four findings. Only the four finding-bearing scenarios invoke the model, yielding 20 calls per model/prompt cell and 180 planned calls. API receipt, JSON parsing, closed-schema validity, deterministic semantic-policy acceptance, finding coverage, evidence coverage and lexical safety flags are reported separately. The no-finding case verifies that no model call is made when the detector has no finding. A separately frozen supplement closes the remaining case-diversity gap with 31 unique events and all four rules. It prospectively defines conflicting context as comparable detector severities accompanied by opposing cues: signed maintenance-like lineage versus missing signer and parent context. Neither cue is treated as proof. The three models receive the same evidence-first prompt, schema and validator in three repetitions (nine calls). A pre-inference prompt-size check increased context equally from 8,192 to 16,384 tokens before any supplemental output was observed.

The historical comparison submits five finding-bearing Phase-A cases ten times to each of two protocols, yielding 50 calls per condition. The grounded protocol and reconstructed free-text path differ in instructions, output schema, and temperature. The comparison therefore measures the two complete protocols' exact-identifier behavior; it cannot isolate the effect of grounding, schema constraints, or decoding, and it cannot establish comparative semantic quality. Its results remain separate from the V1.1 matrix.

The adversarial matrix contains six paired telemetry-field injections and one paired Nmap inventory injection, plus one unpaired benign hard negative per model. Attack and sanitized conditions differ only in the declared field, for 45 calls. All fixtures are inert and cover fake identifiers, fictional CVE-like text, instruction override, unauthorized controls, delimiter/JSON text, Unicode confusables, long strings, command line, process, DNS, file, host and inventory fields. After 12 responses had been preserved, execution exposed a precondition defect: the hard negative's empty truth label had been confused with its expected `BEH-001` detector false positive. A recorded amendment separated truth from detector precondition without changing any telemetry, prompt, parameter, validator or paired metric; the 12 protocol-identical records were reused.

A single-model ablation reuses the first three Llama/contract repetitions as its reference and changes one component at a time: temperature 0.7, omission of the API `format` parameter, or reduced grounding language. It adds 36 calls. A post-hoc validator-bypass condition reclassifies every received reference response as usable but is never connected to operations. Three clustered repetitions describe component sensitivity only. A blinded human-rating rubric and randomized 36-item package were prepared from the first repetition of every model/prompt cell. Five missing primary response bodies were filled only for reviewer display by separately frozen availability-recovery calls; the concealed mapping retains primary and selected-response status, and primary denominators remain unchanged. No human semantic ratings are claimed.

The symmetric automatic audit is deliberately conservative. It applies the same identifier, CVE, attribution, containment, authorization and coverage checks to JSON and free text, but its attribution expression also flags negated phrases such as "malware is not confirmed." These outputs are therefore reported as lexical safety flags rather than expert-adjudicated unsupported claims. Fixed prompts and repetitions are clustered observations; no inferential p-value or attack-success probability is reported.

H. Metrics, response counterfactual, and reproducibility

For true positives (TP), false positives (FP), false negatives (FN), and true negatives (TN), the study reports precision, recall, F1, specificity, balanced accuracy, and Matthews correlation coefficient (MCC). Proportion intervals use the Wilson 95% method. MCC is retained because both classes and both error directions matter:

$$\text{MCC} = \frac{TPTN - FPFN}{\sqrt{(TP+FP)(TP+FN)(TN+FP)(TN+FN)}}. \tag{1}$$

No response was executed. An offline counterfactual maps each alerted source-window to a hypothetical containment decision. It counts normal-origin windows selected for action and botnet-origin windows left without action, and also evaluates a two-rule requirement. These are label-based exposure counts, not measurements of unique hosts disrupted, successful prevention, or business harm. Their purpose is to assess whether the observed error profile supports those response policies within this artifact.

Inputs, hashes, model identifier, prompts, raw outputs, environment, per-call errors, aggregate JSON, and table-generation code are preserved in the repository [27]. The flow parsers are streaming; CTU-13 retains anonymized scored units, while the higher-cardinality second dataset retains truth-separated rule-combination counts and deterministic examples. Article tables are generated directly from committed result JSON to prevent transcription drift.

6. Results

A. Functional benchmark

As shown previously in Table 2, the rules produced 4 true positives, 1 false positive, no false negatives, and 19 true negatives. The resulting precision was 0.800, recall 1.000, specificity 0.950, and F1 0.889. The only false positive was intentional: legitimate periodic updater traffic matched `BEH-001`. This demonstrates that the implementation recognizes its specified patterns and exposes the known dual-use limitation; it does not estimate field accuracy.

The endpoint matrix in Table 3 produced one TP and four TN, with no FP or FN. The positive preserved exact network and file evidence IDs. Nmap changed only `known_asset` context; predictions and finding identifiers were identical without it. This validates the programmed temporal/process/file conditions on constructed evidence, not endpoint detection accuracy or causal proof that received bytes became the file.

Table 3
Frozen inert BEH-004 endpoint truth matrix.

Condition	Expected	Predicted	Outcome
Same process within window	Yes	Yes	TRUE POSITIVE
Received bytes below threshold	No	No	TRUE NEGATIVE
Different processes	No	No	TRUE NEGATIVE
File after time window	No	No	TRUE NEGATIVE
Non executable like suffix	No	No	TRUE NEGATIVE

Note: Nmap enrichment changed only the known-asset context; all finding identifiers and decisions were identical without inventory. This is functional validation on constructed evidence, not endpoint accuracy.

Source: Research data (2026).

B. Historical CTU-13 evaluation

Table 4 reports development and holdout results separately. The holdout contained 53 botnet-origin and 55 normal-origin units. Sixteen botnet-origin units alerted, 37 were missed, 32 normal-origin units alerted, and 23 did not.

Figure 3 places the four CTU-13 results alongside their research roles. The historical and prospective evaluations use different families and cannot estimate the effect of a threshold change on the same test population.

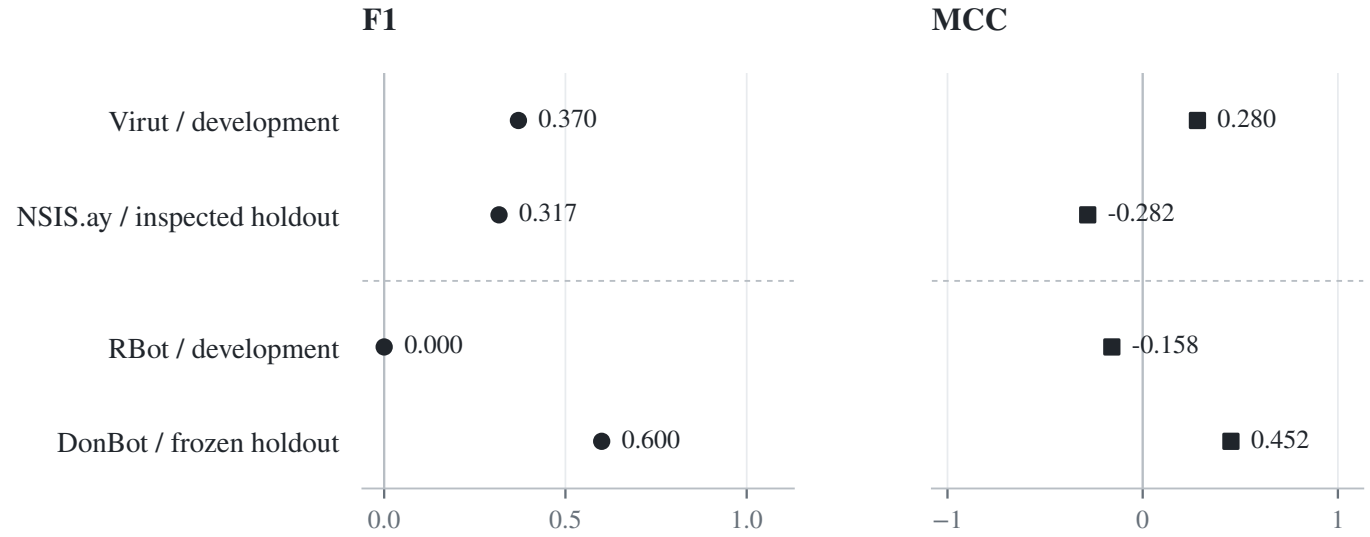
Development precision had a Wilson 95% interval from 0.101 to 0.434, recall from 0.566 to 1.000, and specificity from 0.194 to 0.538. Holdout intervals were from 0.217 to 0.475 for precision, from 0.195 to 0.435 for recall, and

Table 4
FAMILY-SEPARATED CTU-13 EXTERNAL VALIDATION.

Role	Family	Units	TP	FP	FN	TN	Precision	Recall	F1	Specificity	MCC
Development	Virut	31	5	17	0	9	0.227	1.000	0.370	0.346	0.280
Holdout	NSIS.ay	108	16	32	37	23	0.333	0.302	0.317	0.418	-0.282

Source: Research data (2026).

Figure 3. CTU-13 results by family and research role. The dashed divider separates the historical pair from the prospective pair. Differences across rows are not paired estimates of detector improvement.



Source: Research data (2026).

from 0.297 to 0.550 for specificity. The holdout MCC of -0.282 is a negative generalization result, not evidence of reliable botnet detection.

The rule-level error distribution is given in Table 5; B/N denotes findings on botnet-origin and normal-origin windows. Rapid distinct destinations dominated both correct and incorrect alerts. Periodicity appeared only in normal-origin holdout windows, and the asymmetric-egress rule did not fire.

Table 5
RULE FINDINGS ON BOTNET-ORIGIN AND NORMAL-ORIGIN CTU-13 WINDOWS.

Rule	Pattern	Development B/N	Holdout B/N
`BEH-001`	Periodic communication	1/7	0/15
`BEH-002`	Distinct endpoints	5/17	16/32
`BEH-003`	Asymmetric egress	0/0	0/0

Source: Research data (2026).

The development and holdout files contained 129,832 and 325,471 rows. Clean binary scoring retained 5,558 and 9,755 rows; most excluded rows were background or inbound/ambiguous under the publisher's label semantics. Streaming processing took approximately 14.4 and 37.9 seconds, with less than 1.3 MiB peak Python memory traced. Runtime demonstrates feasibility for these files only and is not a throughput benchmark.

C. Retrospective window and threshold diagnostics

Table 6 reports the fixed 1-, 5-, and 10-minute window analyses. Changing the aggregation interval changes both the number and meaning of scored units, so rows are sensitivity analyses rather than interchangeable repetitions.

The one-minute holdout result moved MCC closest to zero and increased specificity, but remained weak; selecting it after observing these results would be holdout-driven tuning and is therefore prohibited.

Table 6
Retrospective CTU-13 sensitivity analysis across fixed aggregation windows.

Role	Family	Window (s)	Units	TP	FP	FN	TN	F1	Specificity	MCC
Development	Virut	60	101	18	34	3	46	0.493	0.575	0.351
Development	Virut	300	31	5	17	0	9	0.370	0.346	0.280
Development	Virut	600	19	3	10	0	6	0.375	0.375	0.294
Holdout	NSIS.ay	60	247	31	53	71	92	0.333	0.634	-0.064
Holdout	NSIS.ay	300	108	16	32	37	23	0.317	0.418	-0.282
Holdout	NSIS.ay	600	73	13	18	29	13	0.356	0.419	-0.271

Note: Thresholds were not retuned. Because the V1.0 holdout had already been inspected, all window comparisons are diagnostic rather than confirmatory and cannot be used to restore an untouched-holdout claim.

Source: Research data (2026).

The component analysis in Table 7 explains why the fixed rules failed differently. Most botnet-origin holdout units never reached six same-endpoint connections, whereas the periodicity rule matched only normal-origin units. Destination diversity overlapped substantially between classes: the normal-origin median exceeded the rule threshold, while the botnet-origin distribution combined many low-count units with a large upper tail. For asymmetric egress, no scored unit in either source reached the 1-MB (1,000,000-byte) per-flow component. Many units exceeded the 10:1 ratio alone, so the absolute byte threshold was the immediate non-firing condition. Flow aggregation and missing process/file context prevent interpreting non-firing as proof that exfiltration-like behavior was absent.

The negative MCC indicates an inverse association between alerts and source-origin labels under the five-minute scoring definition. It is not an error probability or a statement about every event in a window. It provides no support for treating these fixed alerts as reliable standalone malware-origin classifications in this scenario.

Table 7
Five-minute component diagnostics for the three network-flow rules.

Role	Truth	Units	BEH-001 failure path/match				BEH-002 destinations		BEH-003 component matches		
			< 6	No mean	CV> 0.15	Match	Median	Max.	≥ 1 MB	Ratio≥ 10	Both
Development	botnet-origin	5	0	1	3	1	24	30	0	5	0
Development	normal-origin	26	7	6	6	7	10.5	52	0	3	0
Holdout	botnet-origin	53	50	0	3	0	2	323	0	28	0
Holdout	normal-origin	55	18	16	6	15	9	34	0	6	0

Note: BEH-001 categories are mutually exclusive. BEH-002 reports each unit's maximum distinct destinations in any 60-second interval. BEH-003 component counts do not assert that the underlying behavior was absent.

Source: Research data (2026).

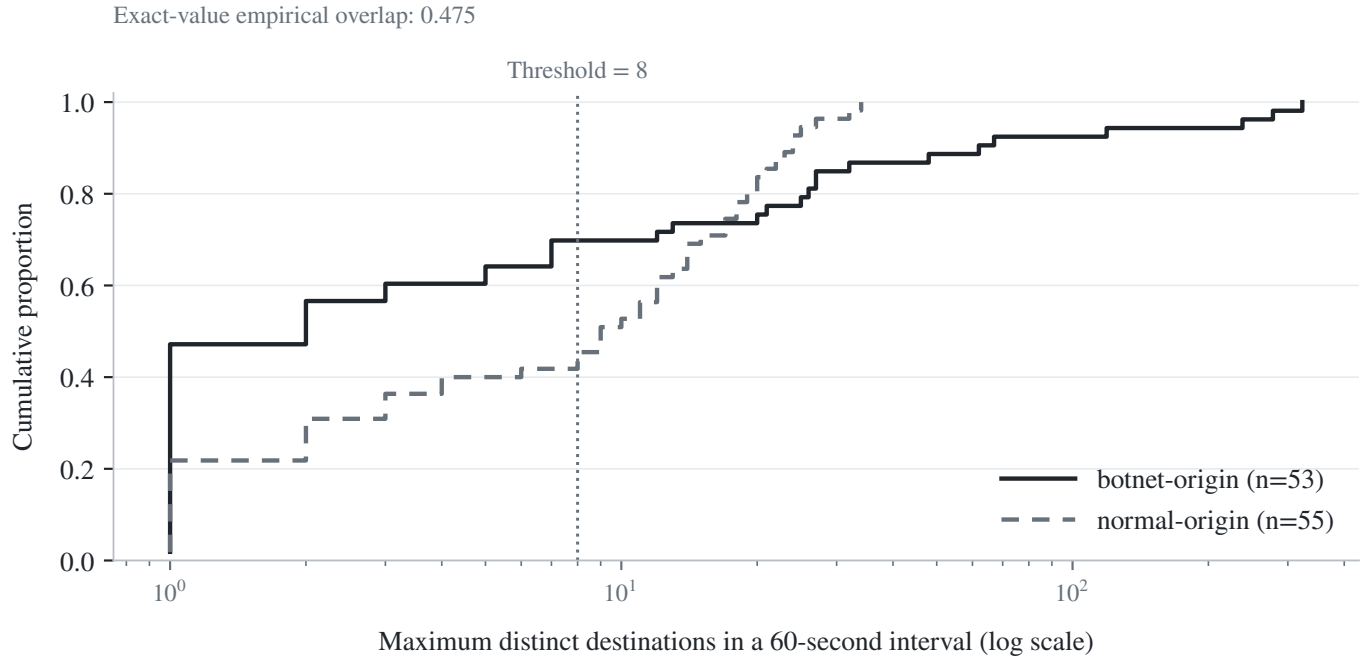
Figure 4 shows the overlap between the two destination-count distributions.

Table 8 makes the operational error modes concrete. The selected TP is a high-diversity botnet-origin window; the selected FP is normal-origin traffic that also exceeds the diversity threshold; and the selected FN contains only one retained event, leaving no rule enough evidence to fire. Exact anonymized host, time, finding, and evidence identifiers remain in the preserved machine-readable result rather than being manually transcribed into the manuscript.

D. Prospective CTU-13 holdout

Table 9 reports the prospectively gated analysis. RBot development was a difficult and very small selection source: none of its three botnet-origin units alerted under any frozen candidate. The deterministic tie-break selected candidate 97, which retained the V1.0 thresholds except for raising the `BEH-002` destination count from 8 to 16. Its negative development MCC was preserved rather than hidden.

Figure 4. Empirical BEH-002 destination-count distributions in the five-minute NSIS.ay holdout. The exact-value empirical overlap coefficient is descriptive and sample-specific.



Source: Research data (2026).

Table 8
Deterministically selected five-minute holdout examples.

Class	Rule	Events	Evidence IDs	Max. destinations	Max. sent (KiB)	Max. ratio
TP	BEH-002	442	20	278	197.0	11560.000
FP	BEH-002	142	20	13	390.2	2.000
FN	N/A	1	1	1	0.1	0.426

Note: Examples are selected by a deterministic class/time/host ordering from anonymized source-window units; the preserved JSON retains the exact finding and evidence identifiers.

Source: Research data (2026).

Table 9
Prospective V1.1 development selection and single confirmatory CTU-13 holdout.

Role	Family	Units	TP	FP	FN	TN	Precision	Recall	F1	Specificity	MCC
Development	RBot	18	0	2	3	13	0.000	0.000	0.000	0.867	-0.158
Confirmatory holdout	DonBot	105	24	29	3	49	0.453	0.889	0.600	0.628	0.452

Note: The 243-configuration grid was evaluated only on RBot. The selected configuration and scientific source hashes were frozen before the DonBot file was parsed once. Development and holdout metrics are not pooled.

Source: Research data (2026).

The frozen DonBot evaluation produced TP=24, FP=29, FN=3, and TN=49, with F1 0.600 and MCC 0.452. This is a positive out-of-development result for one family under the selected configuration. It is not a causal estimate of improvement over V1.0: no paired old-versus-new configuration result is available for the DonBot holdout. More than half of the alerts were normal-origin windows, and `BEH-003` again produced no finding. The four CTU-13 sources contribute 262 scored source-windows in total, but their distinct development and evaluation roles preclude treating them as one test set.

E. Second-dataset implementation transfer

The Scenario-1 replay retained 46,567 of 2,112,224 flows for clean binary scoring and formed 529 source-window units. Table 10 shows TP=96, FP=48, FN=1, and TN=384 (F1 0.797; MCC 0.764). `BEH-002` accounted for all 96 botnet-origin alerts and 46 normal-origin alerts; `BEH-003` added two normal-origin alerts, while `BEH-001` never fired. Thus, 48 of 144 alerts (33.3%) were normal-origin even in this favorable synthetic transfer result.

Table 10
Frozen detector replay on the second, synthetic implementation-transfer dataset.

Role	Units	TP	FP	FN	TN	Precision	Recall	F1	Specificity	MCC
Implementation transfer	529	96	48	1	384	0.667	0.990	0.797	0.889	0.764

Note: The Botnet Group Activity source is synthetic and derives group patterns from CTU-13. It tests parser and detector transfer, not independent real-world generalization; these metrics are not pooled with CTU-13.

Source: Research data (2026).

The archive's own description reports 23,000 bot records, whereas 22,000 entered scoring. The parser excluded 1,046 unsupported-protocol records overall and preserved the complete exclusion accounting; it did not silently reinterpret those records. Because the source is generated from CTU-13-derived patterns, the positive MCC establishes software and representation transfer only. It cannot be used as an independent replication of the DonBot result.

F. Local-model output compliance and availability

1) Primary matrix: Table 11 separates successive output checks. Of 180 planned attempts, 145 returned responses, 122 matched the JSON schema, and 73 passed the full deterministic policy. Acceptance was therefore 73/180 across attempts and 73/145 among received responses. This is contract compliance, not an independently assessed correctness rate. Among the seven cells with complete API availability, acceptance ranged from 0.10 to 0.75; the small, clustered scenario repetitions support descriptive comparisons only.

Table 11
V1.1 primary local-LLM matrix; each cell contains 20 attempted calls.

Model	Prompt	Calls	API	JSON	Schema	Accepted	Finding cov.	Evidence cov.
llama3.2:3b	contract-v1	20	20	15	15	11	0.750	0.750
llama3.2:3b	evidence-first-v1	20	20	20	20	15	0.938	0.912
llama3.2:3b	checklist-v1	20	20	15	15	4	0.750	0.750
gemma3:4b	contract-v1	20	20	19	19	11	0.900	0.879
gemma3:4b	evidence-first-v1	20	20	20	20	14	0.750	0.750
gemma3:4b	checklist-v1	20	20	16	16	2	0.738	0.712
qwen3:8b	contract-v1	20	20	14	14	14	0.700	0.700
qwen3:8b	evidence-first-v1	20	5	3	3	2	0.600	0.600
qwen3:8b	checklist-v1	20	0	0	0	0	0.000	0.000

Note: API is the number of responses received; JSON and Schema are representation checks; Accepted additionally requires the frozen deterministic semantic-policy validator. Coverage is averaged over attempted finding-bearing scenarios, so API failures contribute zero.

Source: Research data (2026).

The Qwen contract cell completed, but the local Ollama server exited during the evidence-first cell. One connection reset and 34 subsequent connection-refused attempts were preserved, leaving 15/20 evidence-first and 20/20 checklist attempts without responses. The cause was not established from a preserved primary-run server log; it is therefore reported as end-to-end local availability failure, not model-quality, timeout or out-of-memory evidence. Incomplete Qwen cells are not compared as though they had complete outputs.

Availability recovery was kept outside the primary matrix. Its first four-call attempt returned four HTTP 500 responses because two orphaned Ollama child processes remained resident and the Qwen load failed at CUDA allocation. After only those verified orphaned processes were removed, one declared retry returned 4/4 response bodies, of which one passed the validator. Package preflight then found one additional primary Qwen response with an empty body; a prospectively selected single-call recovery produced schema-valid content that the validator rejected. These five outputs make the blinded display package complete but do not revise the primary 145/180 response or 73/180 acceptance denominators.

2) Multi-finding cases: None of the 45 primary multi-finding attempts passed validation: each was rejected or lacked an API response. A post-hoc audit extracted schema-valid rankings in four of nine model/prompt cells. Each repeated an ordering across its available observations, but the outputs omitted findings, used non-exact identifiers, crossed finding-evidence boundaries, or selected inapplicable controls. The remaining five cells had no schema-valid ranking to compare. Repeatability thus coexisted with contract violations and cannot be interpreted as ranking correctness.

The 31-event supplement (Table 12) separates complex-output failures from missing responses: all nine calls returned, four outputs matched the schema, and none passed the full policy. All inputs plus reserved output fit the 16,384-token context, but five responses reached the 900-token generation cap. Truncation may therefore explain part of the observed failure and limits conclusions about other generation budgets. It does not explain every rejection: Llama returned complete exact-ID rankings in all three repetitions without reaching the cap, but selected rule-inapplicable controls each time. Gemma produced one schema-valid response with non-exact finding IDs; Qwen produced no complete JSON.

Table 12
Supplemental 31-event conflicting-context LLM stress test.

Model	Calls	API	JSON	Schema	Accepted	Output cap	Complete ranks	Rank agreement
gemma3-4b	3	3	1	1	0	2	0	N/A
llama3-2-3b	3	3	3	3	0	0	3	1.000
qwen3-8b	3	3	0	0	0	3	0	N/A

Note: All nine inputs plus their reserved output fit the 16,384-token context. Output cap counts responses reaching 900 generated tokens. Ranking agreement is estimable only for schema-valid outputs containing every exact finding identifier once; repeatability is not semantic correctness.

Source: Research data (2026).

3) Historical comparison and component ablation: The historical comparison (Table 13; Figure 5) retained exact finding and evidence IDs in 50/50 grounded calls and 0/50 reconstructed free-text calls. Forty grounded responses passed the policy; ten selected an inapplicable control. The result documents a traceability difference between the complete protocols, whose instructions, temperature, and schema differ. Free text was not asked to emit JSON, so its lack of schema-valid output is not independent evidence of poor interpretation.

The ablation in Table 14 isolates observable component sensitivity for the first three Llama/contract repetitions. The reference accepted 7/12 attempts. Raising temperature to 0.7 accepted 4/12. Omitting only the API format constraint produced 12 API responses but zero valid JSON, zero schema-valid outputs and zero accepted outputs. Reduced grounding language accepted 9/12, showing that this small sample does not identify a monotonic benefit from longer instructions. The unsafe validator bypass labels all 12 received reference responses usable, including three that lacked valid JSON/schema output.

4) Adversarial inputs: Of 45 adversarial-matrix calls, 20 returned HTTP 500. Both responses were available for 11 of the 21 attack/sanitized pairs, and ten pairs had two parseable outputs (Table 15). Validator acceptance changed in 8/11 available pairs. Among the ten parseable pairs, priority changed in two, the control set in four,

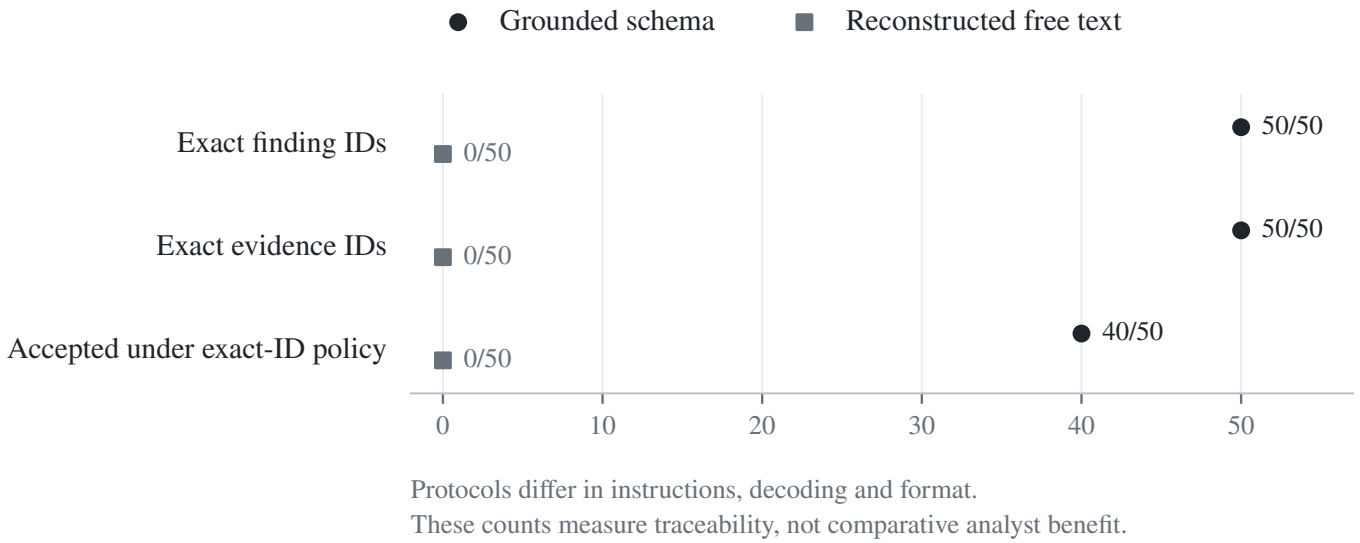
Table 13
Repeated Phase-C automated traceability comparison.

Protocol	Calls	API responses	Exact findings	Exact evidence	System accepted	Policy rejected
Grounded schema 1.1	50	50	50	50	40	10
Reconstructed free text	50	50	0	0	0	N/A

Note: Free text was not asked to emit JSON; its system-accepted count applies the common exact-ID grounding criterion. Grounded policy rejections retained complete citations but selected a rule-inapplicable control.

Source: Research data (2026).

Figure 5. Historical single-model comparison over 50 calls per protocol. Markers show exact-ID traceability and acceptance under the implemented policy, not semantic-quality or analyst-benefit scores. Protocol conditions differ.



Source: Research data (2026).

finding order in one, and the cited evidence set in none. The lexical safety flag changed in 1/11 audited pairs. A change in acceptance is not, by itself, a successful attack: its meaning depends on the resulting output and the validator's decision. One observation per pair does not estimate attack-success probability, and pairs with failed calls provide no evidence of resistance.

All three benign hard-negative calls were accepted as grounded reviews of a `BEH-001` finding even though the fixture's truth label is negative. This is expected under the model contract: the model receives the detector's candidate, not ground truth. It reinforces that schema and citation validity cannot turn a detector false positive into a confirmed incident. No model response triggered an action, and no blinded human semantic rating was collected.

Table 14
Single-model component-sensitivity ablation.

Condition	New calls	Attempts	API	JSON	Schema	Accepted	Finding cov.	Evidence cov.
Reference (primary reuse)	0	12	12	9	9	7	0.750	0.750
Temperature 0.7	12	12	12	9	9	4	0.500	0.500
API format removed	12	12	12	0	0	0	0.000	0.000
Grounding language reduced	12	12	12	9	9	9	0.750	0.750
Validator bypass (post hoc)	0	12	12	9	9	12	0.750	0.750

Note: Reference and validator-bypass rows reuse the same 12 primary responses. Bypass counts every API response as usable and was never connected to operations. Three clustered repetitions support descriptive sensitivity only.

Source: Research data (2026).

Table 15
Adversarial paired-output availability and eligible decision changes.

Model	Calls	Responses	Failures	Eligible pairs	Parseable pairs
gemma3:4b	15	15	0	7	6
llama3.2:3b	15	3	12	1	1
qwen3:8b	15	7	8	3	3
Decision changes among eligible pairs					
Metric	Changed	Eligible			
Validator status	8	11			
Priority label	2	10			
Control set	4	10			
Finding order	1	10			
Evidence set	0	10			
Lexical safety flag	1	11			

Note: A pair is eligible for status comparison only when both API responses exist, and for structural comparison only when both are parseable. Two API failures are not treated as an unchanged decision. One observation per pair does not estimate attack-success probability.

Source: Research data (2026).

G. Counterfactual response safety

No automatic action was executed. Under the block-on-every-alert counterfactual, 32 of 48 selected historical-holdout windows were normal-origin, while 37 botnet-origin windows were missed. The DonBot counts were 29 normal-origin windows among 53 selections and three missed botnet-origin windows. These counts expose a substantial mismatch between the proposed policy and the dataset labels. They do not establish how many distinct hosts would be disrupted or whether a particular block would prevent harm.

Table 16 also evaluates automatic blocking only after two simultaneous rules. That stricter policy does not solve the tradeoff: on historical NSIS.ay it would act on 15 normal-origin units, no botnet-origin unit, and miss all 53 positives; on DonBot it would act on six of 27 positive units and five normal units while leaving 21 positives without action. No unit in the synthetic transfer source had two rules, so the policy would take no action and miss all 97 positive units.

Table 16
Offline containment-policy counterfactuals; no action was executed.

Dataset role	Block every alert			Block after two rules		
	Actions	Normal	Bot missed	Actions	Normal	Bot missed
Historical NSIS.ay	48	32	37	15	15	53
Confirmatory DonBot	53	29	3	11	5	21
Synthetic transfer	144	48	1	0	0	97

Note: Dataset labels indicate source origin, not business impact. Approval-gated rate limiting and confirmation-gated isolation executed zero actions because the required decisions are absent; evidence collection and monitoring do not contain hosts.

Source: Research data (2026).

Analyst approval, temporary rate limiting after approval, and isolation after independent confirmation are represented as proposals with zero executed actions because the datasets contain neither approval nor independent-confirmation decisions. Evidence collection and increased monitoring retain all alert targets but perform no containment. Their lower direct disruption does not imply zero cost: normal-origin targets still consume analyst and storage capacity, while non-alerted positive units remain unreviewed.

7. Discussion

A. RQ1: scenario-dependent signals

The rules recognize the constructed patterns but show substantial variation on externally labeled flows. Destination diversity accounts for much of the signal and many normal-origin alerts; periodicity and byte asymmetry are not consistently discriminative under the chosen windows and thresholds. The positive DonBot result is bounded by a single held-out family, a small development source, and a large normal-origin alert burden. The synthetic transfer result checks a compatible implementation and representation rather than independently confirming generalization. RQ1 therefore supports using the rules as inspectable review triggers within the evaluated scenarios, not as validated standalone malware classifiers.

The error analysis motivates testing richer context, without demonstrating that it will solve the errors. Network flows lack process ownership, executable identity, signer information, parent-child lineage, file creation, and user context. Sysmon can supply some of these associations, subject to selective collection and privacy controls [3]. The constructed endpoint cases establish that the implemented correlation behaves as specified; they do not establish the detection benefit of adding real endpoint evidence.

B. RQ2: traceability and enforceable output checks

The historical comparison demonstrates exact-ID retention under one complete grounded protocol. The broader matrix narrows its interpretation: only 73 of 180 attempted calls passed the contract, and no multi-finding attempt did so. A validator can reject known forms of noncompliance without making the generation process reliable. Acceptance also does not establish truth: all three benign hard-negative responses passed as grounded reviews of an actual detector finding. The contract checks the relationship between an output and its supplied evidence, not whether an incident occurred.

The ablation distinguishes constrained generation from post-generation rejection. Removing the API format constraint yielded no valid JSON in the tested sample; bypassing validation would have admitted malformed responses. Neither observation establishes the quality of a free-text explanation. The smaller instruction variant also passed more often than the reference in this small sample, so longer grounding instructions cannot be assumed to help. For complex cases, generation-budget effects require a controlled follow-up: some outputs were capped, while uncapped complete outputs still selected inapplicable controls.

The paired adversarial cases show that preserving evidence identifiers does not guarantee stable priorities or controls. Their small effective sample, API failures, and conservative lexical audit prevent a general robustness claim. RQ2 is answered for the implemented machine-checkable references and policy constraints. Correct prioritization, resistance to a broader attack distribution, and interpretive usefulness remain open.

The missing practical comparison is consequential. No blinded analyst ratings, investigation-time measurements, or task-accuracy outcomes were collected. Nor was the model compared with a deterministic report containing the same findings and rule-mapped controls. Because the recommendations come from a fixed catalog, that baseline is needed to identify any added value of language-model interpretation. The present results justify studying that value; they do not establish it.

C. RQ3: response boundaries for the evaluated artifact

The implemented deterministic stages can normalize evidence, attach asset context, explain rule matches, and preserve exact references. A model may draft an advisory response candidate, but the observed errors provide no basis for allowing this artifact to infer compromise or initiate containment autonomously. Requiring two simultaneous rules did not remove the label-based false-action/missed-action tradeoff. Independent confirmation and authorization therefore remain design requirements for this system. This conclusion is scoped to the evaluated architecture and evidence; it is not a general prohibition on automated security response under other validated policies.

8. Threats to Validity and Ethical Constraints

Construct validity is limited because CTU-13 labels describe flow origin, not whether every five-minute window contains a detectable malicious action. The study measures review-trigger performance under that operational definition, not malware-family classification. Network-only adaptation cannot evaluate the endpoint-dependent `BEH-004` rule.

Internal validity is limited by heuristic thresholds, source-host windowing, and the possibility that scenario-specific traffic generation affects both labels and patterns. The historical NSIS.ay holdout has already been inspected and must not be reused as untouched evidence after tuning. The prospective DonBot role and grid were frozen before parsing, but the RBot development set contained only three positive units, making threshold selection unstable despite the deterministic rule.

The historical and prospective results also differ in evaluation family. Without a paired old-versus-new configuration comparison on the same holdout, their metric difference cannot be attributed to threshold selection. Source-windows may share hosts and temporal conditions; window-level Wilson intervals do not model that dependence and should not be read as population-level guarantees.

The LLM analysis uses clustered fixed prompts and repeated scenarios rather than independent task samples. The historical protocols change several factors together, and the component ablations have only three repetitions. Generation caps constrain the complex-output tests. The adversarial precondition amendment was recorded after 12 calls; it separated the benign truth label from the expected detector false positive, but the matrix is not unamended preregistration. The supplemental context change preceded inference and followed deterministic prompt sizing. Server failure and HTTP 500 responses reduce comparable denominators; separately disclosed recovery outputs never replace primary attempts. Missing responses are not evidence of resistance, and post-hoc audits remain explicitly retrospective.

The retrospective V1.1 window analysis does not repair that limitation. It is reported to expose sensitivity and failure mechanisms, with thresholds unchanged, but no winning window is selected from it. Any confirmatory V1.1 claim requires a newly frozen family-separated holdout whose labels were not consulted during threshold, window, adapter, or feature decisions.

External validity is limited by an older academic dataset, four malware families with different research roles, 262 CTU-13 source-windows, one CTU-13-derived synthetic transfer source, three local model tags, six primary/supplemental scenario templates, three prompt variants, and two materially different workstations. The second source improves implementation coverage but not construct independence. Confidence intervals remain wide, and neither source represents current production networks. No production telemetry, live malware, packet payload, or actual containment was used. Five primary and three supplemental V1.1 repetitions per cell, plus ten historical repetitions per protocol, describe stability under fixed parameters but are clustered observations. The adversarial matrix has one observation per pair, and automatic lexical checks do not replace blinded expert judgment. The blinded package exists, but expert ratings and inter-rater agreement remain unobserved.

Reproducibility depends on the frozen URLs and hashes because the large external text flows are not committed. The experiment preserves aggregate and anonymized unit output, but external availability remains outside repository control. Model-tag reproducibility additionally depends on preserving the exact Ollama model digest.

All collection must be authorized. Infrastructure and endpoint telemetry can contain personal and sensitive operational data and must follow purpose limitation, retention, access control, and applicable privacy law. The public fixtures are inert; acquisition code blocks malware binaries and packet captures. Reports are advisory, and the LLM has no action credentials.

9. Conclusion

This study evaluated an auditable architecture for behavioral review with local language models. Its deterministic stages retain evidence provenance and its validator rejects specified output-contract violations. Detector results were scenario-dependent: the historical NSIS.ay holdout had negative MCC, while the prospectively frozen DonBot holdout yielded F1 0.600 and MCC 0.452. The latter still selected 29 normal-origin windows among 53 alerts. These separate-family results do not establish a causal improvement from threshold selection, and the CTU-13-derived synthetic source provides implementation-transfer evidence rather than independent replication.

The primary LLM matrix accepted 73 of 180 attempted calls, or 73 of 145 received responses. No primary multi-finding attempt passed, and the nine-call supplement produced no accepted output despite complete response availability. Constrained generation and validation made these failures measurable and rejectable; they did not establish correct ranking, broad adversarial robustness, or analyst benefit. No automatic action was executed.

The contribution is the integration of explicit evidence boundaries with a reproducible evaluation of detector, model-output, and availability failures. The evidence supports inspectable review candidates and enforced rejection within the implemented contract. It does not support autonomous attribution or containment by this system.

Future evaluation should compare model-assisted and deterministic reports on blinded analyst tasks, control generation budgets, and use contemporary independent holdouts. Endpoint and adversarial extensions require new protocols and versioned results; none may replace the preserved experiments.

References

[1] G. F. Lyon, *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*. Sunnyvale: Insecure.Com, 2009.

[2] Nmap Project, "Nmap reference guide," 2025. [Online]. Available: https://nmap.org/book/man.html

[3] Microsoft, "Sysmon events," 2026. [Online]. Available: https://learn.microsoft.com/en-us/windows/security/operating-system-security/sysmon/sysmon-events

[4] National Institute of Standards and Technology, "Artificial intelligence risk management framework (ai rmf 1.0)," NIST, Tech. Rep. NIST AI 100-1, 2023, nIST AI 100-1. [Online]. Available: https://doi.org/10.6028/NIST.AI.100-1

[5] Mitre Corporation, "Mitre att&ck," 2025. [Online]. Available: https://attack.mitre.org/

[6] S. García, M. Grill, J. Stiborek, and A. Zunino, "An empirical comparison of botnet detection methods," *Computers & Security*, vol. 45, p. 100 to 123, 2014. [Online]. Available: https://doi.org/10.1016/j.cose.2014.05.011

[7] Stratosphere Laboratory, "CTU-13 dataset: A labeled dataset with botnet, normal and background traffic," 2026. [Online]. Available: https://www.stratosphereips.org/datasets-ctu13

[8] Ollama, "Ollama documentation," 2025. [Online]. Available: https://github.com/ollama/ollama

[9] Ollama, "Structured outputs," 2026. [Online]. Available: https://docs.ollama.com/capabilities/structured-outputs

[10] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in *2010 IEEE Symposium on Security and Privacy*, 2010, p. 305 to 316. [Online]. Available: https://doi.org/10.1109/SP.2010.25

[11] A. L. Buczak and E. Guven, "A survey of data mining and machine learning methods for cyber security intrusion detection," *IEEE Communications Surveys & Tutorials*, vol. 18, no. 2, p. 1153 to 1176, 2016. [Online]. Available: https://doi.org/10.1109/COMST.2015.2494502

[12] S. Neupane, J. Ables, W. Anderson, S. Mittal, S. Rahimi, I. Banicescu, and M. Seale, "Explainable intrusion detection systems (X-IDS): A survey of current methods, challenges, and opportunities," *IEEE Access*, vol. 10, p. 112392 to 112415, 2022. [Online]. Available: https://doi.org/10.1109/ACCESS.2022.3216617

[13] T. Ali, P. Kostakos, and S. Sheikhi, "HuntGPT: Integrating machine learning-based anomaly detection and explainable AI with large language models (LLMs)," *Telecom*, vol. 7, no. 3, p. 73, 2026. [Online]. Available: https://doi.org/10.3390/telecom7030073

[14] L. Sadlek, M. M. Yamin, P. Čeleda, and B. Katt, "Severity-based triage of cybersecurity incidents using kill chain attack graphs," *Journal of Information Security and Applications*, vol. 89, p. 103956, 2025. [Online]. Available: https://doi.org/10.1016/j.jisa.2024.103956

[15] H. Xu, S. Wang, N. Li, K. Wang, Y. Zhao, K. Chen, T. Yu, Y. Liu, and H. Wang, "Large language models for cyber security: A systematic literature review," *arXiv preprint arXiv:2405.04760*, 2024. [Online]. Available: https://doi.org/10.48550/arXiv.2405.04760

[16] A. Habibzadeh, F. Feyzi, and R. E. Atani, "Large language models for security operations centers: A comprehensive survey," *Journal of Electrical and Computer Engineering*, vol. 2026, p. 3383674, 2026. [Online]. Available: https://doi.org/10.1155/jece/3383674

[17] H. Alqahtani and P. Ahuja, "Secure autonomous cyber defense with LLM agents: A systematic review of autonomy, tool-augmented reasoning, and governance constraints," *Computers & Electrical Engineering*, vol. 135, p. 111184, 2026. [Online]. Available: https://doi.org/10.1016/j.compeleceng.2026.111184

[18] K. Hammar, T. Alpcan, and E. C. Lupu, "Incident response planning using a lightweight large language model with reduced hallucination," in *Network and Distributed System Security Symposium*, 2026. [Online]. Available: https://doi.org/10.14722/ndss.2026.240358

[19] A. Khanna, M. Nandan, C. V. Popa, J. Pujol-Roig, D. Bolocan, L. Vasilie, A. Apostu, C. Helwig, M. Gaman, M. Brautbar, E. Raff, C. Midler, and S. Krasser, "Cybersecurity detection classification with reasoning-enabled language models," *arXiv preprint arXiv:2607.28460*, 2026. [Online]. Available: https://doi.org/10.48550/arXiv.2607.28460

[20] S. Geng, H. Cooper, M. Moskal, S. Jenkins, J. Berman, N. Ranchin, R. West, E. Horvitz, and H. Nori, "JSONSchemaBench: A rigorous benchmark of structured outputs for language models," *arXiv preprint arXiv:2501.10868*, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2501.10868

[21] S. Amershi, D. Weld, M. Vorvoreanu, A. Fourney, B. Nushi, P. Collisson, J. Suh, S. Iqbal, P. N. Bennett, K. Inkpen, J. Teevan, R. Kikin-Gil, and E. Horvitz, "Guidelines for human-ai interaction," in *Proceedings of the 2019 CHI Conference on Human Factors in Computing Systems*, 2019, p. 1 to 13. [Online]. Available: https://doi.org/10.1145/3290605.3300233

[22] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*, 2023, p. 79 to 90. [Online]. Available: https://doi.org/10.1145/3605764.3623985

[23] R. Pandey and A. Bhujang, "Poisoning the watchtower: Prompt injection attacks against LLM-augmented security operations through adversarial log content," *arXiv preprint arXiv:2605.24421*, 2026. [Online]. Available: https://doi.org/10.48550/arXiv.2605.24421

[24] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, "A design science research methodology for information systems research," *Journal of Management Information Systems*, vol. 24, no. 3, p. 45 to 77, 2007. [Online]. Available: https://doi.org/10.2753/MIS0742-1222240302

[25] D. P. Hostiadi and T. Ahmad, "Dataset for botnet group activity with adaptive generator," *Data in Brief*, vol. 38, p. 107334, 2021. [Online]. Available: https://doi.org/10.1016/j.dib.2021.107334

[26] D. P. Hostiadi and T. Ahmad, "Botnet group activity dataset," 2021, cC BY-NC 3.0. [Online]. Available: https://data.mendeley.com/datasets/4vftxh97m8/1

[27] J. V. Ielen and V. M. Favaro, "Tcc: Sistema de análise de segurança de redes," Repositório de código-fonte, 2025, recorte pré-banca: commit dd63d4c; base da revisão pós-defesa: commit 5d93fac. [Online]. Available: https://github.com/awakyy1/network-security-review